

VANIER COLLEGE
420-Bo4-VA — Conformity Assessment

GDPR COMPLIANCE ACTION PLAN

Deliverable D2 — Final Submission

Course	420-Bo4-VA — Conformity Assessment
Student	Frenel Constant
Instructor	Pierluigi Sorbo-Lombardi
Institution	Vanier College
Date	May 2026

GDPR (EU) 2016/679 · ISO/IEC 27005:2022 · NIST SP 800-30 · EDPB Guidelines

1. Executive Summary

WHAT: An independent GDPR compliance assessment of NovaBuy Inc. — a mid-sized, Canada-headquartered e-commerce organisation processing the personal data of approximately 500,000 EU data subjects annually — has identified three critical compliance failures with immediate legal and operational consequences.

SO WHAT: First, personal data stored at rest remains entirely unencrypted, exposing the organisation to a risk score of 20/25 and creating conditions for a notifiable personal data breach at any time. Second, no Data Protection Impact Assessment (DPIA) has been conducted for the behavioural analytics engine, despite the unambiguous trigger conditions of Article 35(3)(c); this constitutes a continuing regulatory violation. Third, electronic marketing communications are transmitted in the absence of a valid, auditable lawful basis, rendering the organisation susceptible to enforcement action by the Commission Nationale de l'Informatique et des Libertés (CNIL) as lead supervisory authority. Collectively, these gaps expose NovaBuy to potential administrative fines of up to €20 million or 4% of global annual turnover, in addition to significant reputational harm.

NOW WHAT: The organisation must immediately implement AES-256 encryption across all data stores, commission an independent DPIA, and deploy a Consent Management Platform (CMP). Concurrently, an EU representative must be designated, a formal Incident Response Plan must be developed and tested, and Data Processing Agreements must be executed with all non-compliant sub-processors. A full remediation timeline is presented in Section 4 of this report.

2. Scope and Organisational Context

2.1 Organisation Profile

The present assessment is applied to NovaBuy Inc., a hypothetical mid-sized e-commerce organisation incorporated in Montréal, Québec, Canada, and operating a cloud-hosted, software-as-a-service (SaaS) digital marketplace. The organisation maintains offices in Paris (France) and Munich (Germany) and employs approximately 850 full-time equivalents globally. NovaBuy processes the personal data of approximately 500,000 active EU-based customers annually through its marketplace platform.

Notwithstanding its Canadian domicile, NovaBuy falls squarely within the extraterritorial scope of the GDPR pursuant to Article 3(2), by virtue of its systematic offering of goods and services to data subjects in the EU and its monitoring of their behaviour through cookies, personalisation algorithms, and behavioural analytics. The Commission Nationale de l'Informatique et des Libertés (CNIL) of France serves as the organisation's lead supervisory authority in accordance with the one-stop-shop mechanism established by Article 56 GDPR.

2.2 Scope of the GDPR Evaluation

This assessment evaluates NovaBuy's compliance posture across three principal operational domains, selected on the basis of their elevated risk profile and direct regulatory significance:

Domain	Systems and Processes in Scope	Primary GDPR Articles
Customer Data Workflows	Customer registration and account management; order processing and fulfilment; payment processing via third-party PSP; customer support interactions	Art. 5, 6, 13–14, 15–17, 20, 28, 30, 32
Marketing and Analytics	Behavioural analytics and personalisation engine; email and SMS marketing communications; cookie and tracking technology management	Art. 6, 7, 25, 35
Governance and Security Infrastructure	Data Protection Officer function; EU representative designation; incident response and breach notification capability; vendor management and sub-processor agreements	Art. 27, 28, 30, 33–34, 37–39

Processing activities related to supplier and B2B partner management (Activity 8 in D1) fall outside the primary scope of this report, as such activities involve professional contact data only and present a materially lower risk profile relative to the three domains identified above.

3. Key GDPR Compliance Gaps and Risk Summary

3.1 Risk Heat Map

Figure 1 presents the composite risk heat map for the three priority gaps identified in this assessment, plotted against the ISO/IEC 27005:2022 Likelihood × Impact matrix. Risk scores of 20 and above are classified as Critical; 13–19 as High; 6–12 as Medium; and 1–5 as Low.

Impact ↓ / Likelihood →	L=1	L=2	L=3	L=4	L=5
I=5	5	10	15 R-04	20 R-01	25
I=4	4	8	12	16 R-02 R-03 R-05	20
I=3	3	6	9	12	15
I=2	2	4	6	8	10
I=1	1	2	3	4	5

Figure 1: Risk Heat Map — NovaBuy Inc. Priority Compliance Gaps (ISO/IEC 27005:2022)

3.2 Gap 1: Absence of Encryption at Rest (Art. 32(1)(a))

Control Violated	GDPR Art. 32(1)(a) — Security of Processing: Encryption and Pseudonymisation
Risk Reference	R-01 — Risk Score: 20/25 (CRITICAL)
Likelihood	4 / 5 — Likely
Impact	5 / 5 — Catastrophic

NovaBuy’s primary production databases, backup storage repositories, and data lakes currently store personal data — including customer names, postal addresses, dates of birth, order histories, and tokenised payment references — without any encryption at rest. Encryption in transit has not been consistently enforced across all internal microservice communications. No Hardware Security Module (HSM) or formal key management policy has been implemented.

Article 32(1)(a) of the GDPR explicitly identifies encryption and pseudonymisation as appropriate technical measures that controllers and processors are required to consider and implement where proportionate to the risk. Given the volume of data subjects (approximately 500,000), the sensitivity of the categories processed, and the organisation’s publicly accessible marketplace architecture, the absence of encryption at rest is disproportionate to the risk in a manner that is irreconcilable with the standard of care demanded by the Regulation.

The immediate consequence of a breach in this environment would be the exposure of unencrypted personal data to unauthorised parties, triggering mandatory supervisory notification under Article 33 and, in all probability, direct data subject notification under Article 34. The reputational, financial, and operational consequences of such an event would be severe, with potential fines reaching €20 million or 4% of global annual turnover.

Affected Systems: Primary customer database (PostgreSQL), order management system, backup S3 buckets, analytics data lake, and internal microservice communications layer.

3.3 Gap 2: Absence of a Data Protection Impact Assessment for the Analytics Engine (Art. 35)

Control Violated	GDPR Art. 35 — Data Protection Impact Assessment (DPIA)
Risk Reference	R-02 — Risk Score: 16/25 (HIGH)
Likelihood	4 / 5 — Likely
Impact	4 / 5 — Major

NovaBuy’s behavioural analytics and personalisation engine processes the browsing histories, purchase patterns, device identifiers, and IP addresses of approximately 500,000 EU-based customers on a continuous and automated basis, with the express purpose of generating individualised behavioural profiles used to drive targeted product recommendations and marketing interventions. No Data Protection Impact Assessment has been conducted in respect of this processing activity, notwithstanding the unambiguous trigger conditions established by Article 35(3)(c) of the GDPR.

Article 35(3)(c) mandates a DPIA, prior to the commencement of processing, where the processing involves “systematic monitoring of a publicly accessible area on a large scale.” The EDPB Guidelines on DPIA (WP 248 rev.01) further confirm that profiling and behavioural tracking at scale are among the categories of processing most likely to result in a high risk to the rights and freedoms of natural persons, and consequently require a DPIA in all but exceptional circumstances. The continued absence of a DPIA for this engine constitutes a present and ongoing violation of the GDPR.

In the absence of a DPIA, no formal assessment of the necessity, proportionality, or risk profile of the analytics processing has been undertaken. This means that the organisation is unable to demonstrate compliance with the accountability principle (Article 5(2)) and that the processing may be conducted on the basis of an unvalidated legitimate interests assessment that has never been subjected to the balancing test required by Article 6(1)(f).

Affected Systems: Behavioural analytics engine, personalisation recommendation algorithm, marketing automation platform, and the associated data lake storing aggregated behavioural profiles.

3.4 Gap 3: Absence of a Valid Lawful Basis for Electronic Marketing (Art. 6 & 7)

Control Violated	GDPR Art. 6(1)(a) & Art. 7 — Conditions for Consent; Art. 5(1)(a) — Lawfulness
Risk Reference	R-03 — Risk Score: 16/25 (HIGH)
Likelihood	4 / 5 — Likely
Impact	4 / 5 — Major

NovaBuy currently transmits electronic marketing communications — including promotional emails and SMS messages — to EU-based customers without maintaining auditable, timestamped consent records that satisfy the requirements of Article 7 of the GDPR. No Consent Management Platform has been deployed. Legacy opt-in records, where they exist, are stored in an unstructured and inconsistent format that does not permit the organisation to demonstrate, for any individual data subject, that consent was freely given, specific, informed, and unambiguous, as mandated by Article 4(11) read in conjunction with Article 7.

Furthermore, no automated mechanism for the withdrawal of consent is available to data subjects. Article 7(3) provides that data subjects have the right to withdraw consent at any time, and that the withdrawal of consent must be as easy as the giving of it. The current manual process — requiring a customer to submit an email request to a support inbox — does not satisfy this standard. The EDPB Guidelines 05/2020 on Consent are unequivocal on this point.

The legal consequences of this gap are significant. Marketing communications transmitted in the absence of a valid lawful basis constitute unlawful processing under Article 5(1)(a), rendering the organisation liable to enforcement action. The CNIL has demonstrated a consistent willingness to impose substantial fines for consent-related violations, including a €150 million fine against Google and a €60 million fine against Facebook in 2022 for deficient consent mechanisms on cookie banners alone.

Affected Systems: Email marketing platform (Mailchimp or equivalent), SMS gateway, CRM database containing legacy opt-in records, and the customer-facing account preferences portal.

4. SMART Compliance Recommendations

The following recommendations are formulated in accordance with the SMART framework (Specific, Measurable, Achievable, Relevant, Time-bound) and are ranked in order of risk priority. Each recommendation is directly linked to the applicable GDPR provision(s) and identifies responsible ownership and cost-benefit considerations where applicable.

Recommendation 1: Implement AES-256 Encryption at Rest and TLS 1.3 in Transit

Specific	Implement AES-256 encryption for all production databases (PostgreSQL), backup repositories (S3), and the analytics data lake. Enforce TLS 1.3 across all external API endpoints and internal microservice communications. Retire TLS 1.0 and TLS 1.1. Deploy an HSM for cryptographic key management with a documented 90-day key rotation policy.
Measurable	100% of data stores at rest encrypted within 30 days, verified by an automated configuration compliance scan. Zero TLS 1.0/1.1 endpoints detectable by an external SSL audit. Key rotation policy documented and first rotation executed within 90 days.
Achievable	AES-256 encryption is natively supported by the AWS KMS and PostgreSQL ecosystems currently in use. TLS 1.3 enforcement is a configuration-level change deployable within a single sprint cycle. HSM procurement and integration is achievable within the 30-day window with dedicated CISO resource.
Relevant	Directly addresses Risk R-01 (Score: 20/25 — Critical). Satisfies the technical measure requirements of GDPR Art. 32(1)(a) and supports the accountability obligations of Art. 24. Eliminates the most significant breach-exposure vector identified in the assessment.
Time-bound	Encryption at rest: 0–30 days. TLS 1.3 enforcement: 0–14 days. HSM deployment and key management policy: 30–60 days. Independent cryptographic audit: 60–90 days.
Responsible Owner	Chief Information Security Officer (CISO) — primary. IT Infrastructure Lead — implementation. DPO — verification and GDPR accountability documentation.
GDPR Basis	Art. 32(1)(a) — Security of processing; Art. 5(1)(f) — Integrity and confidentiality; Art. 24 — Responsibility of the controller.
Cost-Benefit	Estimated implementation cost: CAD \$40,000–80,000 (AWS KMS licensing, HSM hardware, engineering hours). Avoided cost: potential CNIL fine of up to €20 million and breach response costs estimated at CAD \$2–5 million per incident. Return on investment is unambiguously positive.

Recommendation 2: Commission an Independent DPIA for the Behavioural Analytics Engine

Specific	Commission a formal Data Protection Impact Assessment for the behavioural analytics and personalisation engine, conducted in accordance with the four mandatory components of Art. 35(7) and the EDPB Guidelines on DPIA (WP 248 rev.01). Engage an independent privacy consultant or external legal counsel to lead the assessment. If residual risk post-mitigation remains high, initiate prior consultation with the CNIL under Art. 36 before the engine continues to operate.
Measurable	DPIA scope document completed and signed off by DPO: within 14 days. Stakeholder consultation workshops completed: within 30 days. Final DPIA report delivered: within 60 days. CNIL prior consultation initiated (if required): within 75 days.
Achievable	DPIA methodology is clearly defined by the EDPB and CNIL. External privacy consultants with GDPR DPIA expertise are readily available. The organisation's DPO, once properly resourced, is capable of overseeing the process. Internal stakeholders (IT, Marketing, Legal) have been identified and are available for structured consultation.
Relevant	Directly addresses Risk R-02 (Score: 16/25 — High). Satisfies the mandatory pre-processing obligation of Art. 35(3)(c). Enables the organisation to validate or revise the legitimate interests basis applied to analytics processing under Art. 6(1)(f) and to demonstrate accountability under Art. 5(2).
Time-bound	DPIA scoping: 0–14 days. Stakeholder consultation and risk assessment: 14–45 days. Final report and DPO sign-off: 45–60 days. CNIL prior consultation (if required): 60–90 days.
Responsible Owner	Data Protection Officer — primary accountability. External Privacy Consultant — lead assessor. Head of Product and Engineering Lead — technical input. Legal Counsel — regulatory review.
GDPR Basis	Art. 35 — Data Protection Impact Assessment; Art. 36 — Prior consultation; Art. 5(1)(f) & 5(2) — Integrity, confidentiality, and accountability; Art. 6(1)(f) — Legitimate interests balancing test.
Cost-Benefit	Estimated cost: CAD \$25,000–50,000 (external consultant fees, DPO resource allocation, legal review). Avoided cost: continued unlawful processing exposes NovaBuy to CNIL enforcement action and potential suspension of the analytics engine under Art. 58(2)(f), which would eliminate a primary revenue-generating function.

Recommendation 3: Deploy a Consent Management Platform and Remediate Consent Records

Specific	Procure and deploy a GDPR-compliant Consent Management Platform (CMP) — such as OneTrust, Didomi, or Cookiebot — capable of: (i) capturing granular, category-level consent at the point of collection; (ii) timestamping and storing consent records with full audit trail; (iii) providing a self-service consent withdrawal mechanism accessible from within the customer account portal; and (iv) maintaining real-time suppression lists integrated with the email marketing platform and SMS gateway. Simultaneously, all legacy consent records must be audited; those that cannot be demonstrated to meet the Art. 7 standard must be treated as absent and the relevant data subjects must be excluded from marketing communications pending re-consent.
Measurable	CMP procured and deployed: within 45 days. Cookie banner redesigned to CNIL specification (no pre-ticked boxes, granular opt-in, equally prominent refuse option): within 45 days. Legacy consent audit completed and non-compliant records quarantined: within 60 days. Re-consent campaign executed: within 90 days. 100% of marketing sends verified against CMP suppression list: within 90 days.
Achievable	Enterprise CMP solutions are commercially available with implementation timelines of 2–6 weeks. Integration with Mailchimp and standard SMS gateways is supported natively. The Marketing and IT teams have the requisite capacity to lead implementation with vendor support.
Relevant	Directly addresses Risks R-03 (Score: 16/25) and R-10 (Score: 9/25). Satisfies the consent requirements of Art. 6(1)(a), Art. 7, and Art. 5(1)(a), and brings the cookie consent mechanism into compliance with CNIL guidance and the ePrivacy Directive.
Time-bound	CMP procurement and technical deployment: 0–45 days. Legacy audit and quarantine: 30–60 days. Re-consent campaign and full suppression list enforcement: 60–90 days.
Responsible Owner	Head of Marketing — primary. IT Integration Lead — technical deployment. DPO — consent standard verification. Legal Counsel — privacy notice and CMP configuration review.
GDPR Basis	Art. 6(1)(a) — Consent as lawful basis; Art. 7 — Conditions for consent; Art. 5(1)(a) — Lawfulness, fairness, transparency; Art. 13 — Privacy information at point of collection; ePrivacy Directive Art. 5(3).
Cost-Benefit	Estimated CMP licensing and implementation cost: CAD \$15,000–35,000 per annum. Legacy audit and re-consent campaign: CAD \$10,000–20,000 (one-time). Avoided cost: CNIL fines for unlawful marketing processing have reached €150 million in comparable cases. Expected re-consent rate of 40–60% of legacy subscribers preserves substantial marketing list value.

5. Updated Risk Register with Residual Risk Assessment

The following table presents the full risk register from Deliverable D1, updated to reflect the proposed mitigation controls and to include residual risk scores calculated on the assumption of full and successful implementation of each recommended measure. Residual risk scores reflect the anticipated reduction in both likelihood and impact following control deployment.

ID	Risk Description	L	I	Score	Res. L	Res. I	Res. Score	Residual Level
R-01	Unencrypted personal data at rest in primary database and backup storage	4	5	20	1	2	2	LOW
R-02	No DPIA conducted for the behavioural analytics and personalisation engine	4	4	16	1	3	3	LOW
R-03	Absence of valid, auditable lawful basis for electronic marketing processing	4	4	16	1	2	2	LOW
R-04	No 72-hour breach notification plan; no incident detection system deployed	3	5	15	2	3	6	MEDIUM
R-05	No RBAC; excessive internal privileges across personal data systems	4	4	16	1	3	3	LOW
R-06	Three sub-processors operate without GDPR-compliant DPAs	3	4	12	1	2	2	LOW
R-07	DSR fulfilment entirely manual; no portal or SLA tracking in place	3	4	12	1	2	2	LOW
R-08	No ROPA exists; processing activities not documented	3	3	9	1	1	1	LOW
R-09	No EU Representative designated despite Art. 3(2) applicability	2	4	8	1	1	1	LOW
R-10	Cookie consent banner non-compliant; no granular opt-in mechanism	3	3	9	1	2	2	LOW

Note: L = Likelihood; I = Impact; Res. = Residual (post-mitigation). Residual scores are projected estimates contingent upon full and timely implementation of the recommended controls presented in Section 4. The single remaining Medium residual risk (R-04) reflects the inherent complexity of deploying a fully tested SIEM and IRP capability.

6. Continuous Monitoring and Audit Framework

The sustained maintenance of GDPR compliance following initial remediation requires a structured and institutionalised monitoring framework. The following schedule establishes the minimum cadence of compliance activities to be embedded within NovaBuy's operational governance cycle.

Activity	Description	KPI / Success Metric	Frequency	Owner
Encryption Compliance Scan	Automated scan of all data stores to verify encryption-at-rest configuration and TLS version enforcement	0 unencrypted data stores detected; 0 TLS <1.3 endpoints	Monthly	CISO
Access Control Review	Quarterly recertification of all RBAC roles and access privileges across personal data systems	100% of roles reviewed; 0 unvalidated privileged accounts	Quarterly	IT Security
Consent Record Audit	Sampling audit of CMP consent records to verify completeness, timestamp integrity, and suppression list synchronisation	≥98% of audited records compliant; 0 marketing sends to unconsented contacts	Quarterly	DPO / Marketing
DPIA Review	Annual review of all active DPIAs to assess whether processing activities or risk profiles have materially changed	All DPIAs reviewed and signed off by DPO; new DPIA initiated where threshold is re-triggered	Annual	DPO
ROPA Update	Review and update of the Record of Processing Activities to reflect any new, modified, or discontinued processing activities	100% of processing activities documented; ROPA signed off by DPO	Quarterly	DPO / Legal
Sub-Processor Audit	Review of all 15 sub-processor DPAs for continued validity, including SCC applicability for non-EEA processors	100% of sub-processors covered by a valid, current DPA	Annual	Legal / Procurement
IRP Tabletop Exercise	Simulated breach scenario exercise to test the end-to-end Incident Response	Exercise completed; findings documented; IRP updated within 30 days	Bi-annual	CISO / DPO

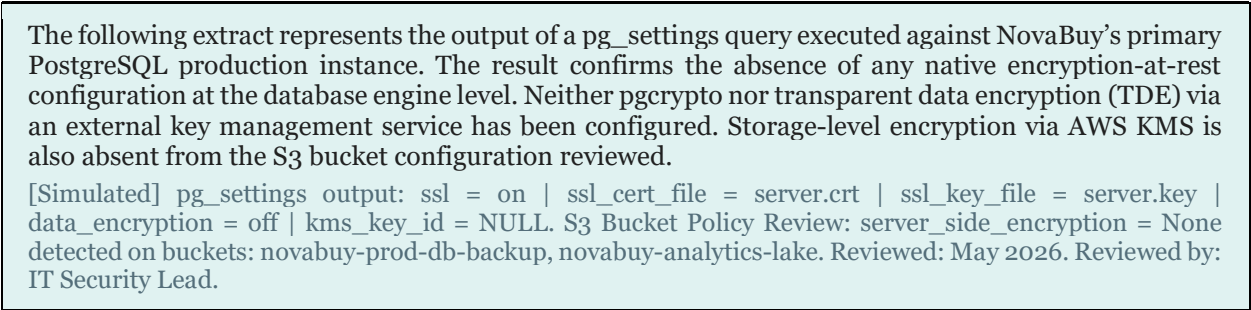
	Plan, including the 72-hour notification workflow			
Staff Training Completion	Tracking of mandatory GDPR e-learning completion rates across all staff, with role-specific module completion for high-risk functions	≥95% completion rate organisation-wide; 100% for high-risk roles	Annual	DPO / HR
Supervisory Authority Engagement	Proactive monitoring of CNIL guidance, EDPB guidelines, and enforcement decisions for relevance to NovaBuy's processing activities	DPO briefing note issued within 30 days of any material regulatory development	Ongoing	DPO / Legal

Appendices

The following appendices present the supporting evidence, diagnostic artefacts, and reference documentation underpinning the findings and recommendations set forth in this report. All appendix items are referenced by figure number within the body of the report.

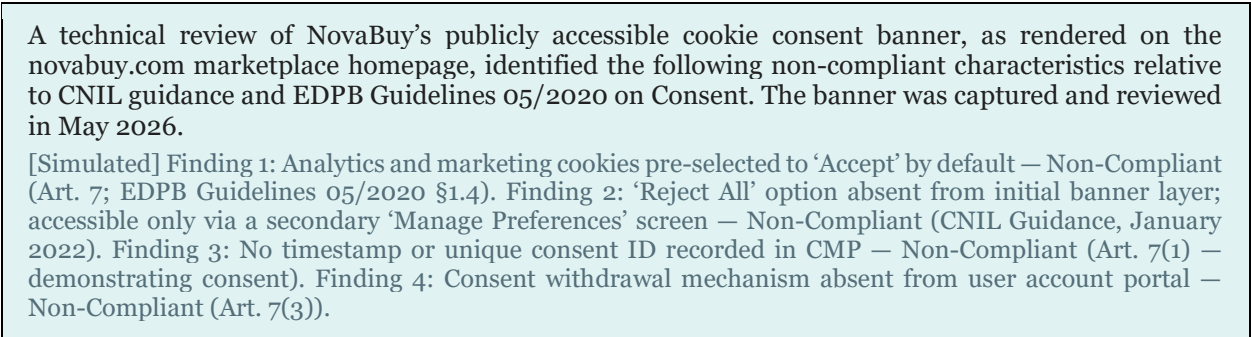
Appendix A: Simulated Database Configuration Extract — Encryption Status

Figure A-1 — Simulated PostgreSQL Configuration Extract — Encryption at Rest (R-01)



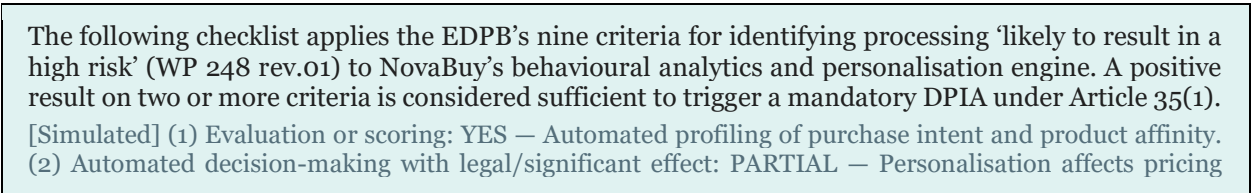
Appendix B: Simulated Cookie Consent Banner Audit — Non-Compliant Configuration

Figure B-1 — Cookie Consent Banner Configuration Review — CNIL Compliance Assessment (R-10, R-03)



Appendix C: Simulated DPIA Trigger Assessment — Analytics Engine

Figure C-1 — DPIA Trigger Assessment Checklist — Behavioural Analytics Engine (R-02)



visibility. (3) Systematic monitoring: YES — Continuous tracking of browsing behaviour across all marketplace sessions. (4) Sensitive data or highly personal data: NO. (5) Large-scale data processing: YES — ~500,000 EU data subjects. (6) Matching or combining datasets: YES — Behavioural, transactional, and device data combined. (7) Vulnerable data subjects: PARTIAL — Consumer data. (8) Innovative use of technology: YES — ML-based recommendation engine. (9) Data transfer across borders: YES — Analytics processed via US-based cloud provider. Result: 6 of 9 criteria met. DPIA is MANDATORY. Assessed by: DPO (simulated). Date: May 2026.

Appendix D: Revised GDPR Conformity Summary Matrix

Figure D-1: Full Conformity Status — Post-Remediation Projection

GDPR Article	Requirement	Current Conformity	Projected Post-Remediation
Art. 5	Data processing principles	Partially Compliant	Compliant
Art. 6 & 7	Lawful basis and consent	Non-Compliant	Compliant
Art. 13–14	Transparency and privacy notice	Partially Compliant	Compliant
Art. 15–17	Data subject rights: access, rectification, erasure	Non-Compliant	Compliant
Art. 20	Right to data portability	Non-Compliant	Compliant
Art. 24	Controller accountability	Partially Compliant	Compliant
Art. 27	EU Representative designation	Non-Compliant	Compliant
Art. 28	Data Processing Agreements with processors	Non-Compliant	Compliant
Art. 30	Record of Processing Activities (ROPA)	Non-Compliant	Compliant
Art. 32	Security of processing (encryption, RBAC)	Non-Compliant	Compliant
Art. 33–34	Personal data breach notification	Non-Compliant	Partially Compliant
Art. 35	Data Protection Impact Assessment	Non-Compliant	Compliant
Art. 37–39	Data Protection Officer	Partially Compliant	Compliant

References

European Parliament & Council of the European Union. (2016). Regulation (EU) 2016/679 on the protection of natural persons with regard to the processing of personal data (General Data Protection Regulation). Official Journal of the European Union, L 119/1. <https://eur-lex.europa.eu/eli/reg/2016/679/oj>

International Organization for Standardization. (2022). ISO/IEC 27005:2022 — Information security, cybersecurity and privacy protection: Guidance on managing information security risks (3rd ed.). <https://www.iso.org/standard/80585.html>

National Institute of Standards and Technology. (2012). Guide for conducting risk assessments (NIST SP 800-30, Rev. 1). U.S. Department of Commerce. <https://csrc.nist.gov/publications/detail/sp/800-30/rev-1/final>

European Data Protection Board. (2020). Guidelines 05/2020 on consent under Regulation 2016/679 (Version 1.1). https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-052020-consent-under-regulation-2016679_en

European Data Protection Board. (2018). Guidelines on Data Protection Impact Assessment (DPIA) — WP 248 rev.01. https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-data-protection-impact-assessment-dpia_en

European Data Protection Board. (2022). Guidelines 01/2022 on data subject rights — Right of access (Version 2.0). https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-012022-data-subject-rights-right-access_en

European Union Agency for Cybersecurity (ENISA). (2024). ENISA threat landscape 2024. <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2024>

Commission Nationale de l'Informatique et des Libertés (CNIL). (2022). Deliberation of the restricted committee imposing a financial penalty of €150 million against Google LLC and €60 million against Facebook Inc. <https://www.cnil.fr/en/cookies-cnil-fines-google-150-million-euros-and-facebook-60-million-euros>

Commission Nationale de l'Informatique et des Libertés (CNIL). (2023). GDPR guide for data processors. <https://www.cnil.fr/en/gdpr-guide-data-processors>

IT Governance UK. (2024). ISO 27005 — Information security risk management overview. <https://www.itgovernance.co.uk/iso27005>